VETRI × TNEGA E-SEVAI 2.0 · INTERNAL · NOT FOR SUBMISSION

# EOI Readiness Report

How the VETRI codebase measures up against TNeGA's Expression of Interest for the Business Process Management & Workflow Orchestration Platform of the *Vetri Tamil Nadu Integrated e-Sevai 2.0* platform: what is expected, what exists, what is missing and what must be built.

| EOI reference | Issued | Submission due | Report date |
|---|---|---|---|
| **TNeGA/EOI/e-Sevai 2.0/2026-2027** | **23 Oct 2026** | **3 Nov 2026 · 16:00** | **27 Oct 2026** |

## Verdict: VETRI cannot be offered as "the platform" today.

The EOI asks for a **configurable BPMN 2.0 / DMN engine** on which admins build every service without code. VETRI is a polished citizen-services app whose single workflow is hard-coded in TypeScript. **0 of 90** requirements are fully met. The deciding blockers are **not code**: ≥2 live deployments (Cl. 5.3), an Indian legal entity (Cl. 6b) and a DSC.

**48** of 90 requirements **not met**

**42** of 90 only **partly met**

**0** requirements **fully met**

**10** **critical / high** security defects

**0 / 18** Govt DPI connectors **live**

**0 / 7** Format 6 BPMN/DMN core items (1–7)

**70** features to build, in 8 workstreams

**7 days** to the 3 Nov 2026, 16:00 deadline

## How this was checked

**Read the EOI** — All 30 pages, every clause, format and annexure → **7 assessors** — One per requirement group, reading the code for file:line evidence → **7 sceptics** — Each tried to disprove every Yes/Partly and re-search every No → **Licence research** — Engines & stack, with sources (27 Oct 2026)

### Do this week

- Go / no-go on entity, live deployments, DSC (today)
- Fix the 10 security defects before any demo
- Remove fabricated figures & overclaiming copy
- Submit honest Format 5 / 6 / 7 by Mon 2 Nov

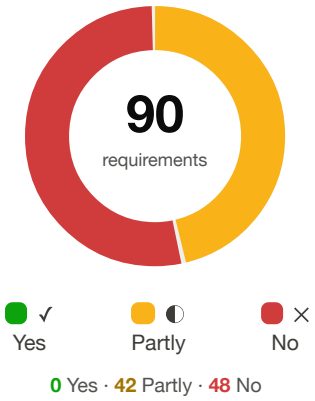
### Recommended path

- Route A: Operaton BPMN/DMN + bpmn-js + Keycloak + APISIX
- VETRI as the citizen front-end & integration accelerator
- No entity or live deployments? Partner with an SI/OEM
- 70 features to RFP-readiness, 11 of them P0

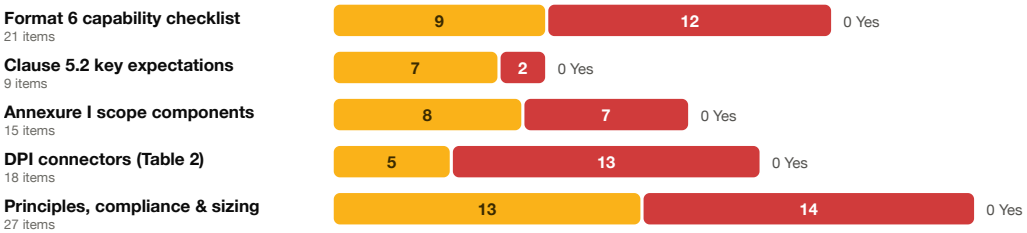
Static review of the working tree; nothing was executed (no Docker/DB on the review machine). Where two reviewers disagreed, the lower rating was kept, because under **Clause 9.5** misleading information gets a response disregarded.

# Scorecard: every EOI requirement, rated

90 requirements across five parts of the EOI. Not one is fully met. Bars are drawn to the same scale, so length = count.




**0** Yes · **42** Partly · **48** No




## What the EOI wants vs what VETRI is today

| TNeGA expects | VETRI today |
|---|---|
| A configurable BPM engine: BPMN 2.0 workflows + DMN rules | One hard-coded 15-stage workflow in TypeScript |
| Admins create & change services without writing code | Every service = code in two catalogues + redeploy |
| 1–10 level approval chains routed to posts & jurisdictions | One officer click; routed to a named officer |
| 18 live DPI connectors (Aadhaar, e-Sign, DigiLocker, PayGov …) | 10 mock adapters; no business flow calls them |
| Sovereign Tamil + English AI on TNeGA servers | Regex keyword chat; voice audio goes to Google/Apple |
| 50,000 concurrent users, >99% uptime, STQC / VAPT / DPDPA | Single instance, zero tests, critical auth bypass |

## Target vs today

| | |
|---|---|
| **Services on the platform** | **21, all hand-coded** / target up to 1,000 |
| **Services admins can configure** | **0** / target all |
| **Approval levels per service** | **1** / target 10 |
| **DPI connectors live** | **0 (5 mocks)** / target 18 |
| **Departmental portals live** | **0 (6 mocks)** / target ~15 |
| **UI files with Tamil** | **14 of 73 (19%)** / target 100% |
| **Format 6 capabilities fully met** | **0** / target 21 |
| **Automated test files** | **0** / target full suite + CI |

**≤ 5 s per action on 2 Mbps**
Today ≈ 3–8 s first visit: 0.75–2 MB, nothing compressed.

**1.2–1.5 lakh requests/day peak**
Throttle caps the whole platform ≈ 2 req/s behind a load balancer.

**> 99% availability**
No HA/DR/backups; health check returns OK even when the DB is down.

# What TNeGA expects

e-Sevai 2.0 replaces today's Java/.NET e-Sevai 1.0 with one AI-native platform where every service (forms, workflow, rules, approvals, documents, payments, notifications, certificates) is **configured, executed, monitored and changed** on a BPM engine.

### e-Sevai 1.0 today

| 275 | 25,277 | 1.4 Cr |
|---|---|---|
| services · 38 depts | e-Sevai centres | transactions / year |

### e-Sevai 2.0 target (Table 3)

| 1,000 | 50k | 1.5 L |
|---|---|---|
| services | concurrent users | peak requests / day |

| 10 | 1 L | >99% | ≤5 s |
|---|---|---|---|
| approval levels per service | department users | availability, 24×7×365 | per action on 2 Mbps |

## 15 scope components (Annexure I)

| | | |
|---|---|---|
| 01 Core platform | 02 Identity (CAN, SSO) | 03 AI / ML layer |
| 04 Service onboarding | 05 Portal integrations | 06 DPI integrations |
| 07 "No Application" delivery | 08 Beneficiary mgmt | 09 e-Sevai operations |
| 10 Citizen grievance | 11 Analytics | 12 Channel readiness |
| 13 Legacy migration | 14 Deployment | 15 Compliance |

## Three solution routes (Cl. 5.1)

**Route A**
Open-source BPMN/DMN engine + custom build. All source vests with TNeGA.

**Route B**
Existing product customised. Source shared, or perpetual licence + SDK.

**Route C**
Hybrid, e.g. open-source engine + product components.

### Non-negotiables for every route (Cl. 5.2)

- **a** No recurring licence fee
- **b** Licensed OSS, nothing older than n-2
- **c** BPMN 2.0 / DMN XML, open formats
- **d** Full source + independent build
- **e** IPR vests with TNeGA
- **f** Configuration first, no code
- **g** On-prem & sovereign, incl. AI
- **h** OpenAPI · OIDC · OAuth 2.0 · SAML · multi-tenant
- **i** Mobile-first

### What must be submitted (Cl. 8.1)

- **F1** Covering letter
- **F2** Respondent profile, delivery & support capability
- **F3** Projects + **≥ 2 live deployment case studies**
- **F4** Expert professionals by technology
- **F5** Product note ≤ 8 pages (Q1–Q6 + Part B)
- **F6** 21-item capability checklist
- **F7** Licensing schedule

> Non-binding and unscored (Cl. 7.1c). It feeds the RFP. TNeGA may reuse ideas without attribution (Cl. 9.2).

# Fix before anyone sees a demo

10 confirmed defects. **None is behind a mock or demo flag**: compose runs `NODE_ENV=production` and the frontend talks to the live backend by default. TNeGA may invite a technical presentation (Cl. 7), and these would be found there.

| 6 | 4 | 0 | ~1 wk |
|---|---|---|---|
| critical | high | gated by a mock flag | to fix the top 8 (S-sized) |

| # | Severity | Defect | Evidence | Impact |
|---|---|---|---|---|
| 1 | !! Critical | **Login issues an ADMIN token to anyone, no OTP** | `auth.service.ts:44–57` | Every RBAC guard is moot |
| 2 | !! Critical | **Every login binds to the first seeded citizen** | `auth.service.ts:60` | One person's PII for all; audit actor meaningless |
| 3 | !! Critical | **Role drift: citizen refresh token returns ADMIN** | `auth.service.ts:65–67,85–91` | Privilege escalation |
| 4 | !! Critical | **Citizen self-approves into a "verified" certificate** | `applications.controller.ts:28–31` | "Check for updates" × 9 = certificate |
| 5 | !! Critical | **Full Aadhaar number stored in plaintext** | `auth.service.ts:31` → `Otp.identifier` | Aadhaar Act / UIDAI violation |
| 6 | !! Critical | **Boot-time `db push --accept-data-loss`; failed count re-seeds** | `docker-entrypoint.sh:7,16–19` | A DB blip can wipe everything, incl. audit |
| 7 | ! High | **IDOR on documents & notifications; statewide officer queue** | `documents.service.ts:24–27` | Read anyone's documents |
| 8 | ! High | **Fixed OTP 123456, no SMS, no mode flag** | `auth.service.ts:28` | Trivial account takeover |
| 9 | ! High | **Default secrets; DB/Redis/pgAdmin published; root; EOL Node** | `docker-compose.yml`, `Dockerfile` | Fails VAPT on day one |
| 10 | ! High | **Voice audio & replies go to Google/Apple/Microsoft** | `useVoice.ts:23–65` | Breaks Cl. 4.2(c), 5.2(g) |

**Exploit, one request:** `POST /api/auth/verify {"method":"biometric","role":"admin"}` returns a full ADMIN token. After that, a citizen's next token refresh also returns ADMIN.

## Also confirmed

- Swagger UI public in every environment; raw internal errors returned to clients; no CSP.
- Refresh tokens stored in plaintext; `User.active` never checked; sessions never closed.
- Citizen PII persisted in browser localStorage, which is unsafe on shared e-Sevai kiosk browsers.
- Audit log records only successful mutations, always attributed to the first officer.

# Format 6: capability checklist

The 21 capabilities TNeGA will ask "Yes / Partly / No" for, with honest answers. **12 No** · **9 Partly** · **0 Yes**. Items 1–9 are the BPM engine itself: all No.

| # | Expected capability | Status | What exists today | What is missing |
|---|---|---|---|---|
| 1 | **Browser-based BPMN 2.0 process modeller, usable by trained administrators** | No | No modeller. One hardcoded 15-stage TypeScript state machine (`workflow.engine.ts:21–55`); seeded Workflow tables are never read. | bpmn-js modeller → BPMN XML per service → an executing engine with a publish/deploy flow. |
| 2 | **Approval chain of 1–10 levels, sequential or parallel, with return to an earlier level** | No | A single officer action; "approve" jumps any stage straight to completed (`officer.service.ts:59–61`). | Configurable levels per service, approver post per level, parallel joins, return to any level. |
| 3 | **Routing of each task to a post (designation) and jurisdiction, not a named individual** | No | Auto-assigns a named officer by district + least load (`applications.service.ts:94–116`); queues ignore it. | Post/position entities, LGD-coded jurisdiction hierarchy, queues per post that survive transfers. |
| 4 | **SLA for each level, with reminders and escalation on breach** | No | 3 display-only `slaDays` constants; `slaDeadline` never written; `jobs/` empty; BullMQ unused. | Per-level SLA config, deadline timers, reminders, auto-escalation, holiday calendar. |
| 5 | **Process versioning and migration of in-flight applications to a new version** | No | Version fields are labels only. | Draft/published versions, instances pinned to a version, in-flight migration tool. |
| 6 | **Business rules as DMN decision tables, with import / export** | No | No DMN. Complaint routing is if/else; `EligibilityRule` seeded but never evaluated. | DMN engine (FEEL, hit policies), decision-table editor, XML import/export. |
| 7 | **Plain-language rule builder for officers (eligibility, fees, document checklist)** | No | Eligibility, fees and checklists are catalogue constants in code. | Tamil/English condition builder with test/simulate and maker-checker. |
| 8 | **Rule versions effective by date, applied as per the date of application** | No | One global code-defined stage graph. | Effective-dated rule/form/workflow versions resolved by application date. |
| 9 | **Drag-and-drop form builder with Tamil and English (Unicode) support** | No | A real schema-driven form *renderer* (`forms/engine.ts:51–73`), but forms are TS constants; labels English-only. | Form designer, DB-stored versioned definitions, server-side validation, bilingual labels. |
| 10 | **Officer worklist and actions: approve, reject, return, forward, seek report** | Partly | Approve, reject, correction, escalate, transfer are persisted with audit + citizen notification. | "Forward" along a chain, "seek report"; worklist scoped to the logged-in officer. |
| 11 | **e-Sign / DSC on approval, including bulk approval** | No | Only an uncalled mock CA adapter. | ESP e-Sign + DSC/HSM signing, signed PDF certificates, bulk select-and-sign. |
| 12 | **Delegation, leave and Full Additional Charge handover** | No | Nothing. | Date-ranged delegation/charge, work routed to the delegate, audit. |
| 13 | **REST / SOAP connectors to Departmental systems, with retry on failure** | Partly | Uniform adapter interface + registry; all 10 adapters return canned data; no workflow calls them. | Real REST/SOAP transports, retry/backoff, circuit breaker, DLQ, admin config. |
| 14 | **Published APIs (OpenAPI) for web, mobile and messenger channels** | Partly | Swagger UI + spec at `/api/docs`, used by the web app. | Complete schemas, API versioning, partner/channel auth, developer portal. |
| 15 | **On-premises deployment on containers, with BPMN / DMN export** | Partly | Backend Dockerfile + docker-compose (Postgres, Redis). | Frontend image, Kubernetes/IaC, HA; BPMN/DMN export (no models exist). |
| 16 | **Mobile-compatible screens for citizens, operators and officers** | Partly | Citizen mobile shell + desktop portal; officer pages at phone width. | No operator / e-Sevai-centre persona at all. |
| 17 | **Native mobile apps (Android / iOS) through SDKs or APIs** | Partly | A REST + JWT API that a native app could consume. | SDK, push (FCM/APNs), API versioning, PWA/offline. |
| 18 | **Reporting tools, with reports configurable without coding** | No | Nothing (citizen-side .txt exports only). | Report designer, saved/scheduled reports, CSV/XLSX/PDF export. |
| 19 | **Analytics and dashboards** | Partly | Role-guarded dashboards wired to APIs, but most figures are hard-coded (`analytics.service.ts:31–89`). | Real aggregation from workflow history; filters by department/district/service. |
| 20 | **API gateway to monitor and manage all services** | Partly | In-app throttling, JWT and request logs only. | A gateway (e.g. APISIX), service registry, per-consumer keys/quotas, metrics. |
| 21 | **Identity and access management (role-based) across all modules** | Partly | Role guard + permission catalogue. | Identity bound to role (security defect #1), user/role admin, OIDC/SAML. |

# Clause 5.2: key expectations

Format 5, Part B asks for Met / Partly met / Not met on each. Today: **0 Met · 7 Partly · 2 Not met**. The two misses, open standards and configuration-first, are the heart of the EOI.

| Clause | Expected | Position | What exists | Gap |
|---|---|---|---|---|
| 5.2 a | **No recurring licence fee** | Partly met | All dependencies permissive OSS; no paid SaaS keys. | No SBOM/licence register; `redis:7` image is likely RSAL/SSPL → switch to Valkey; build docs assume Docker Desktop. |
| 5.2 b | **Licence, versions and updates (≤ n-2)** | Partly met | Licences fine. | `@nestjs/swagger` 7 is beyond n-2; NestJS 10, Prisma 5, TS 5, Postgres 16 sit at the n-2 limit; Node 20 is EOL; no component register. |
| 5.2 c | **Open standards: BPMN 2.0 / DMN XML; open formats** | Not met | Nothing in BPMN/DMN. | No BPMN/DMN storage, export or import; forms have no documented open schema. |
| 5.2 d | **Source code and independent build** | Partly met | Full source, Dockerfile, compose, docs. | No CI/CD, no IaC, zero automated tests; two conflicting lockfiles per project. |
| 5.2 e | **Ownership / IPR vests with TNeGA** | Partly met | Bespoke code, permissive deps. | No LICENSE / IPR statement / NOTICE; no provenance for CM portrait, State emblem, boundary data. |
| 5.2 f | **Configuration first (forms, workflows, approvals, rules, fees, notifications, certificates)** | Not met | Admins can broadcast messages and toggle browser-local flags. | None of the 7 items is configurable without code. |
| 5.2 g | **On-premises and sovereign, incl. the AI layer** | Partly met | Backend self-hostable, no vendor SaaS. | Browser speech sends audio to Google/Apple/Microsoft; Google Fonts at runtime; Prisma telemetry/binary downloads. |
| 5.2 h | **Interoperability: OpenAPI, OIDC, OAuth 2.0, SAML, multi-tenant** | Partly met | Partial OpenAPI; JWT auth. | No OIDC, OAuth 2.0 or SAML; no multi-tenancy. |
| 5.2 i | **Mobile-first** | Partly met | Real citizen mobile shell renders all 21 forms. | Dead/mock mobile screens (SOS, helplines, fake status bar); no PWA/offline. |

## What VETRI genuinely brings: use these, honestly

**Citizen experience.** Polished phone + desktop shells, TN-specific look, Tamil scheme data from the API, Tamil voice in/out (to be moved on-prem).

**Shared pipeline.** A generic schema-driven form renderer; one application, wallet, notification and audit path shared by 20 services.

**Sound plumbing.** NestJS with audit interceptor, helmet, validation whitelist, throttling, refresh-token rotation; all-permissive OSS licences.

**Integration seam.** A uniform adapter interface shaped for DPI connectors, plus an auto-generated OpenAPI spec.

Position VETRI as a **citizen front-end and integration accelerator** on top of a standards-based engine, not as the engine.

# Annexure I: the 15 scope components

**0 Yes · 8 Partly · 7 No.** Two more gaps are not rated in the EOI tables: **payments** (the Payment table is never written) and **monitoring / change management** of live services.

| # | Component expected | Status | What exists today | What is missing |
|---|---|---|---|---|
| 1 | **Core platform: web portal + UI library, microservices, API gateway, BPMN/DMN engine, form builder, docs & templates, dashboard, notifications, tracker** | Partly | Two-shell React UI, component library, citizen dashboard, NestJS monolith with Swagger, tracker. | BPMN/DMN engine, form builder, template engine, API gateway, service registry. |
| 2 | **Identity: CAN, SSO, IAM, CAN de-dup, Aadhaar/ration-card linkage** | No | CAN is a seeded string; login issues any role to anyone. | Real auth, SSO, CAN lifecycle, de-duplication, linkages. |
| 3 | **AI/ML: Tamil+English NLP, document AI, semantic search, officer workbench, Tamil voice, grievance AI** | No | Regex keyword chat; browser speech (vendor cloud). | Every model and the sovereign hosting. |
| 4 | **Service onboarding at scale (275 → 1,000 services)** | Partly | Metadata-driven rendering of 21 code-defined services. | Two catalogues already out of sync; every service = code + redeploy. |
| 5 | **~15 Departmental portal integrations** | Partly | 6 mock departmental adapters behind an uncalled endpoint. | Any live integration. |
| 6 | **National & State DPI integrations (Table 2)** | Partly | Mock stubs only. | All 18 live connectors (next page). |
| 7 | **"No Application" service delivery** | No | Browser prefill from the citizen's own profile/drafts. | Pull from Govt databases, eligibility triggers, consent. |
| 8 | **Beneficiary management + scheme registry** | Partly | Read-only seeded registry of 9 schemes. | Eligibility evaluation, beneficiary lists, scheme admin. |
| 9 | **e-Sevai centre operations** | No | UI copy only. | Centre registry, operator login, assisted filing, fees, analytics. |
| 10 | **Citizen grievance + CM Cell (IIPGCMS)** | Partly | Complaint intake with hardcoded routing. | Status never moves past "submitted"; no IIPGCMS. |
| 11 | **Analytics: reports and dashboards** | No | Dashboards run on fabricated constants. | Real data mart, filters, reports. |
| 12 | **Channel readiness: mobile, messenger, UMANG, IVRS, call centre** | Partly | Swagger REST only. | Channel adapters, partner auth, versioning. |
| 13 | **Legacy data migration (~110 TB)** | No | Nothing; no object storage. | ETL, mapping, reconciliation, document ingestion. |
| 14 | **Deployment on TNeGA infrastructure** | Partly | Single-host docker-compose. | HA, IaC, CI/CD, backups, DR. |
| 15 | **Compliance: STQC, VAPT, DPDPA, GIGW 3.0, UX4G, WCAG 2.1 AA** | No | Baseline hygiene only. | Everything (see compliance page). |

# The 18 Government connectors (Table 2)

**0 of 18 live.** 5 have mock adapters that return canned data (Partly); 13 have nothing. Tier A needs a legal entity, third-party audits and Government approvals. No amount of code can deliver it alone.

| 0 | 5 | 13 |
|---|---|---|
| live connectors | mock adapters only | nothing at all |

## Tier A · certification-gated: third-party audit + explicit go-live approval

### 1. Aadhaar auth & e-KYC
AUA/KUA via ASA

Partly — Mock adapter, uncalled

Go-live: **UIDAI onboarding + audit**

### 2. e-Sign
≥2 CCA-empanelled ESPs

Partly — Mock CA adapter

Go-live: **ASP registration with ESPs**

### 3. DigiLocker / e-Pettagam
Issuer + Requester

Partly — Mock; internal wallet only

Go-live: **NeGD partner onboarding**

### 4. PayGov, PG, UPI, wallets, AEPS
Pay, refund, reconcile

Partly — Mock; Payment table unused

Go-live: **PayGov onboarding**

### 5. Meri Pehchaan / TN SSO
Identity management

No — Nothing

Go-live: **OIDC federation**

### 6. State Family Database
Consent-bound pre-fill

No — Nothing (family always empty)

Go-live: **TNeGA access approval**

## Tier B · sandbox and functional certification

### 7. API Setu
Publisher + consumer

No — Own OpenAPI only

Go-live: **Sandbox certification**

### 8. Nambikkai Inaiyam
Anchor certificate hashes

No — Nothing

Go-live: **Blockchain client**

### 9. IIPGCMS (CM Cell)
Petitions + ATRs

No — Internal intake only

Go-live: **Sandbox certification**

### 10. e-Courts
Citizen services

No — Nothing

Go-live: **API access**

### 11. CCTNS
Police citizen services

No — Constant stub

Go-live: **TN Police API agreement**

### 12. UMANG
Publish service APIs

No — Nothing

Go-live: **UMANG onboarding**

### 13. SMS, WhatsApp, e-mail, push, IVRS
Notifications

Partly — In-app feed; channel mocks

Go-live: **DLT SMS, WhatsApp BSP**

### 14. CSC-SPV
Assisted networks

No — Nothing

Go-live: **CSC integration**

## Tier C · registry or reporting

### 15. LGD
Jurisdiction master

No — Free-text place names

Go-live: **LGD code sync**

### 16. e-Taal / State Portal
Transaction counts

No — Constant dashboards

Go-live: **Count feeds**

### 17. Open Government Data
Performance datasets

No — Hardcoded pages

Go-live: **Dataset publishing**

### 18. TNGIS
Location services

No — Decorative SVG map

Go-live: **TNGIS APIs + PostGIS**

# Principles, hosting, compliance & sizing

27 cross-cutting requirements: **13 Partly · 14 No**. Every compliance regime except WCAG is a flat No, and all of them need certificates or audits that take months.

| Ref | Expected | Status | What exists / gap |
|---|---|---|---|
| **Guiding principles (2.4)** | | | |
| i | **Transformation, not translation** | Partly | Profile prefill + wallet reuse; no proactive / "No Application" delivery. |
| ii | **Integrated, not individual services** | Partly | Shared application/wallet/notification modules; department is free text; workflowId/Payment never read. |
| iii | **ICT infrastructure on demand** | Partly | Stateless JWT API; no K8s/autoscaling; Redis/BullMQ never used; in-memory throttler. |
| iv | **Cloud by default** | Partly | Containerised backend; no IaC, TLS, secrets manager or object storage. |
| v | **Mobile first** | Partly | Mobile citizen shell; no PWA/service worker; manual shell choice. |
| vi | **GoI / State standards and protocols** | Partly | Unicode Tamil, OpenAPI; gateway hard-coded to "mock"; no LGD codes. |
| vii | **Tamil and English everywhere** | Partly | ~143 keys in 14 of 73 UI files; forms, notifications, AI replies English-only. |
| viii | **GIS via national/State platforms** | No | Decorative SVG only; no TNGIS/Bhuvan, geocoding or PostGIS. |
| ix | **Security and electronic data preservation** | Partly | helmet, validation, throttling, JWT rotation; but the critical defects, no TLS, no encryption at rest. |
| **Hosting (4.2)** | | | |
| a | **Containers, vendor-neutral** | Partly | Backend containerised; root user, EOL Node, no frontend image. |
| b | **AI stack on TNeGA infra; citizen data never leaves** | No | No models; voice audio and fonts go to third parties. |
| **Compliance (4.1 j)** | | | |
| DiTN | **DiTN 2023** | No | Nothing. |
| STQC | **STQC readiness** | No | Zero tests, no CI, no test plans. |
| VAPT | **CERT-In VAPT + 2022 Directions** | No | Fails on the 10 security defects; no 180-day India log retention. |
| DPDPA | **DPDPA 2023 + Rules 2025** | No | No consent notice/ledger; "Data Sharing Consent" pre-ticked ON and inert; plaintext Aadhaar. |
| GIGW | **GIGW 3.0** | No | No policy pages, sitemap or accessibility statement; lang fixed to "en". |
| UX4G | **UX4G design system** | No | Not adopted; inline styles across 73 files. |
| WCAG | **WCAG 2.1 AA** | Partly | aria-labels, focus rings, reduced motion, high contrast; outline removed on inputs, no skip link, no audit. |
| **Sizing (Table 3)** | | | |
| SZ-1 | **Up to 1,000 services** | Partly | DB catalogue, but each service is hand-written code + redeploy. |
| SZ-2 | **60k–1.2 L req/day avg; 1.2–1.5 L peak** | Partly | Unproven; throttle shares one 120 req/min bucket behind a load balancer. |
| SZ-3 | **≥ 50,000 concurrent users** | No | Single instance, no cache, no pooler or replicas. |
| SZ-4 | **50k–1 L department users** | No | Department users cannot log in as themselves. |
| SZ-5 | **Up to 10 approval levels** | No | One linear pipeline. |
| SZ-6 | **> 99% availability, 24×7×365** | No | /health returns 200 when the DB is down; no HA/DR/backups. |
| SZ-7 | **≤ 5 s per action on 2 Mbps at peak** | Partly | Code-split routes; first visit ≈0.75–2 MB, no compression → 3–8 s. |
| **Migration & quality** | | | |
| MIG | **~110 TB legacy data migration** | No | No ETL, no object storage. |
| TEST | **Automated tests + CI** | No | Jest installed, zero spec files. |

# Don't repeat these claims

Clause 9.5: false or misleading information gets a response disregarded. These statements exist in the app or docs today. Remove or correct them before any submission, slide or demo.

| Claim in the repo | Where | Reality |
|---|---|---|
| **"Every registry is data, not code … added by configuration"** | `AdminPortal.tsx:128`, `workflow/types.ts:4` | Everything is TypeScript constants. |
| **"Production-grade"** | `backend/README.md:3`, `ARCHITECTURE.md:3` | Zero tests, auth bypass, data-wiping boot. |
| **"© Government of Tamil Nadu" / "Official Citizen Services Portal"** | `DesktopFooter.tsx:47`, `translations.ts:53` | A prototype styled as an official portal. |
| **"never stores your Aadhaar … shared only when you authorise"** | `DesktopProfile.tsx:186–187`, `loginCopy.ts:85` | Plaintext Aadhaar; any user reads any document. |
| **"Session: Encrypted" / "Encrypted-at-rest seam"** | `DesktopProfile.tsx:179`, `AdminPortal.tsx:108` | No TLS, no encryption at rest. |
| **Department / MLA / transparency dashboards** | `analytics.service.ts:31–89` | Hard-coded figures. |
| **"Uptime 99.9%", officer KPIs 47 / 92% / 96%** | `AdminPortal.tsx:90`, `officer.service.ts:45–46` | Constants served as live. |
| **"every reply bilingual"** | `PHASE3.md:71` | Live AI replies are English-only. |
| **"real auth pipeline … exactly what production would"** | `DemoMode.tsx:12–15` | This page is the auth bypass. |
| **Fee step: "payment method recorded"** | `DesktopServiceFlow.tsx:507–508` | No payment data is submitted. |

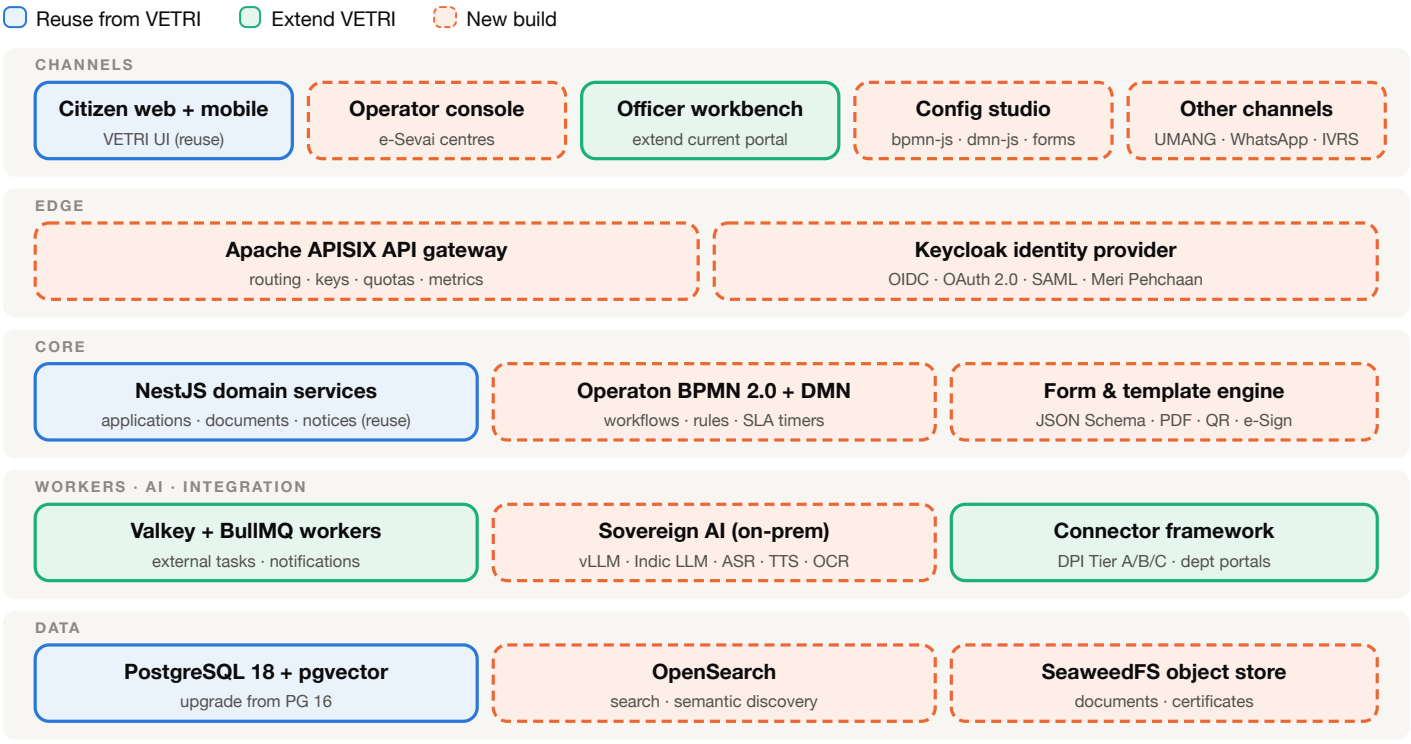
## Blockers that no code can fix

| | Requirement | Clause | Status |
|---|---|---|---|
| ☐ | **Legal entity registered in India + incorporation certificate** | 6(b) | To confirm |
| ☐ | **≥ 2 LIVE deployments of the proposed solution, with client referral** | 5.3, F3(B) | To confirm |
| ☐ | **Govt projects of last 7 years with work-order numbers** | F3(A) | To confirm |
| ☐ | **tntenders.gov.in registration + Class-3 DSC; EOI signed on every page** | 8.4 | To confirm |
| ☐ | **OEM authorisation letter (Operaton has no OEM: say so)** | 6(c) | To confirm |
| ☐ | **Not engaged by TNeGA in preparing this EOI** | 9.4(c) | To confirm |
| ☐ | **"VETRI" is your product, not the "Vetri Tamil Nadu" programme; clear emblem & CM portrait** | 9.5, 5.2(e) | To confirm |

**Most likely deciding gap:** Cl. 5.3 asks for at least two **live** deployments of the proposed solution, each with a client referral TNeGA may call (Cl. 7.2).

# Recommended: Route A, open-source engine + VETRI

**Operaton** (an Apache-2.0 fork of Camunda 7) is the only fully free, actively released engine with BPMN 2.0 + DMN + FEEL. Camunda 8 needs a paid production licence; Camunda 7 CE reached EOL in Oct 2025. Fallbacks: Flowable 8, Fluxnova.




Runs entirely on the TNeGA State Data Centre · Kubernetes · Prometheus / OpenTelemetry / Grafana · no foreign cloud at runtime

## Format 7: draft licensing schedule

| Row | Component | Proposed | Licence |
|---|---|---|---|
| 1 | **BPMN/DMN engine + modeller** | Operaton 2.2 + bpmn-js / dmn-js | Apache-2.0; bpmn.io (keep watermark) |
| 2 | **Product (Route B)** | Not applicable (Route A) | — |
| 3 | **Database, search, vector** | PostgreSQL 18 · OpenSearch 3 · pgvector | PostgreSQL · Apache-2.0 |
| 4 | **Gateway, broker, cache** | Apache APISIX · Valkey + BullMQ | Apache-2.0 · BSD-3 · MIT |
| 5 | **Identity provider** | Keycloak 26 (OIDC, OAuth 2.0, SAML) | Apache-2.0 |
| 6 | **AI models (on-prem)** | vLLM · Sarvam-30B · IndicTrans2 · IndicConformer · IndicF5 · Tesseract | Apache-2.0 / MIT |
| 7 | **Security / DevSecOps** | To be researched | — |
| 8 | **Monitoring** | Prometheus · OpenTelemetry · Jaeger · Grafana/Loki | Apache-2.0 · AGPL-3.0 (declare) |
| 9 | **Others** | SeaweedFS object store · rjsf / JSON Forms | Apache-2.0 · MIT |

Versions and licences come from web research on 27 Oct 2026. **Re-check every version on submission day**: n-2 is judged against the latest release then. Watch-outs: the bpmn.io watermark clause, AGPL on Grafana/Loki, Redis 7.4+ is not OSI (use Valkey), MinIO repo archived.

# Your three options

### A · Partner

Join an established SI/OEM's response; VETRI is the citizen-UX and integration layer.

+ Their live deployments cover Cl. 5.3
– Shared credit, dependency

**Best if no entity or live deployments**

### B · Respond as a start-up

Route A: Operaton + bpmn-js + Keycloak + APISIX + sovereign AI, VETRI as accelerator; honest F5/F6.

+ Direct visibility; shape the RFP via Q6
– Cl. 5.3 gap; ideas reusable (Cl. 9.2)

**Cheap if documents exist**

### C · Skip, build for RFP

Use the time to close the P0/P1 gaps and enter at the RFP stage.

+ No submission risk
– No influence on the RFP terms

**Fallback**

## Seven-day plan to the deadline

- **Tue 27 Oct** **Go / no-go.** Do you have an entity, two live deployments and a DSC? If not, contact an SI/OEM who is responding. Start tntenders.gov.in registration + DSC now.
- **Wed 28 Oct** **Security fixes** S1–S6 (auth, roles, self-approval, Aadhaar, scoping, safe deploys).
- **Thu 29 Oct** **Honesty pass** (S10): remove fabricated numbers, "Govt of TN" branding, overclaiming copy. Draft Format 6 + Format 5 Part B from this report.
- **Fri 30 Oct** **Product note** (F5, ≤ 8 pages): Q1 Route A · Q2 Operaton licence · Q3 what is configurable · Q4 BPMN/DMN portability · Q5 real largest deployment · Q6 suggestions.
- **Sat 31 Oct** **Optional PoC:** Operaton + bpmn-js running one service with a 3-level approval, a DMN fee table and an SLA timer, driven from the VETRI UI.
- **Sun 1 Nov** **Formats 1–4 + 7**: profile, projects, experts, licensing schedule (re-verify versions). Architecture diagram.
- **Mon 2 Nov** **Sign every page, assemble, upload**, one day early in case the portal has problems.
- **Tue 3 Nov** **16:00 deadline.** Buffer only.

## Format 5, Part A: draft answer outline

| Q | TNeGA asks | Suggested honest answer |
|---|---|---|
| Q1 | **Which Solution Route, and why?** | Route A: Operaton BPMN 2.0/DMN + bpmn-js/dmn-js, VETRI as the citizen front-end. Meets 5.2 a–c with no licence fee. |
| Q2 | **Engine licence, version, end of support, paid features?** | Operaton 2.2 (Apache-2.0, no commercial edition, no paid features); 6-monthly minors + monthly patches. Re-verify on the day. |
| Q3 | **What can admins configure without code?** | **Today: nothing.** Proposed: forms, workflows, approval chains, DMN rules, fees, notification and certificate templates. Developers: new connectors, AI models, custom UI. |
| Q4 | **Upgrades after hand-over; moving engine or agency?** | BPMN/DMN XML + JSON Schema forms port to Flowable, Fluxnova or Camunda. Full source, IaC and CI handed over; patches follow the Operaton release train. |
| Q5 | **Largest live deployment?** | State your real numbers. If none is live, say so: do not cite VETRI demo figures. |
| Q6 | **Suggestions (optional)** | Consent design for SFDB pre-fill · Tamil-first UX · assisted-channel parity for e-Sevai centres · a reference BPMN service library · on-prem Tamil speech. |

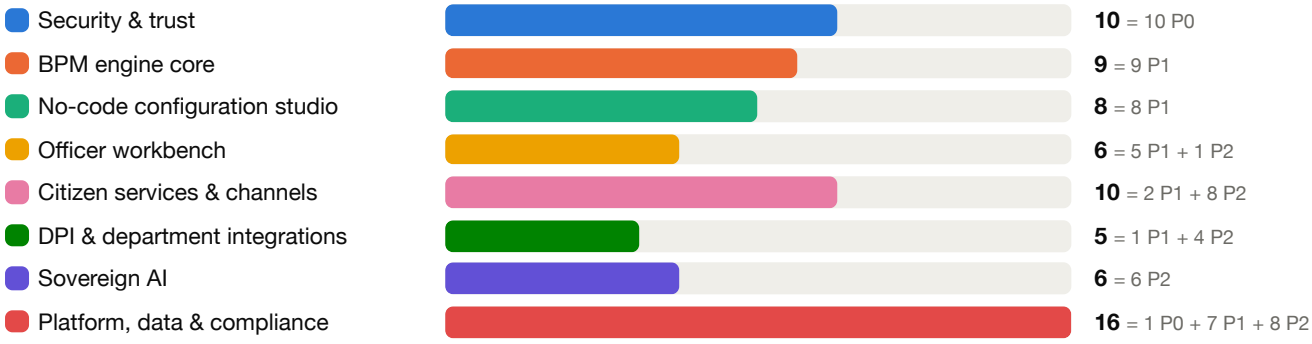
> The PoC turns several "No" answers into "demonstrated in a proof of concept". It still does **not** make them "Yes" in Format 6.

# What must be built: 70 features

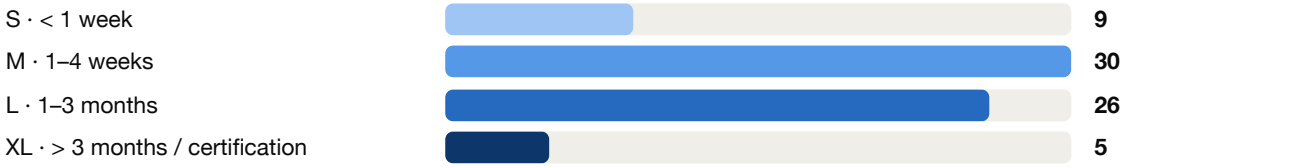
Every gap above turned into a buildable feature, grouped into 8 workstreams. **P0** = before any demo or submission · **P1** = RFP-critical core · **P2** = build-out for full e-Sevai 2.0 scope.

| 11 | 32 | 27 |
|---|---|---|
| **P0** · before any demo | **P1** · RFP-critical core | **P2** · full-scope build-out |

### Features per workstream

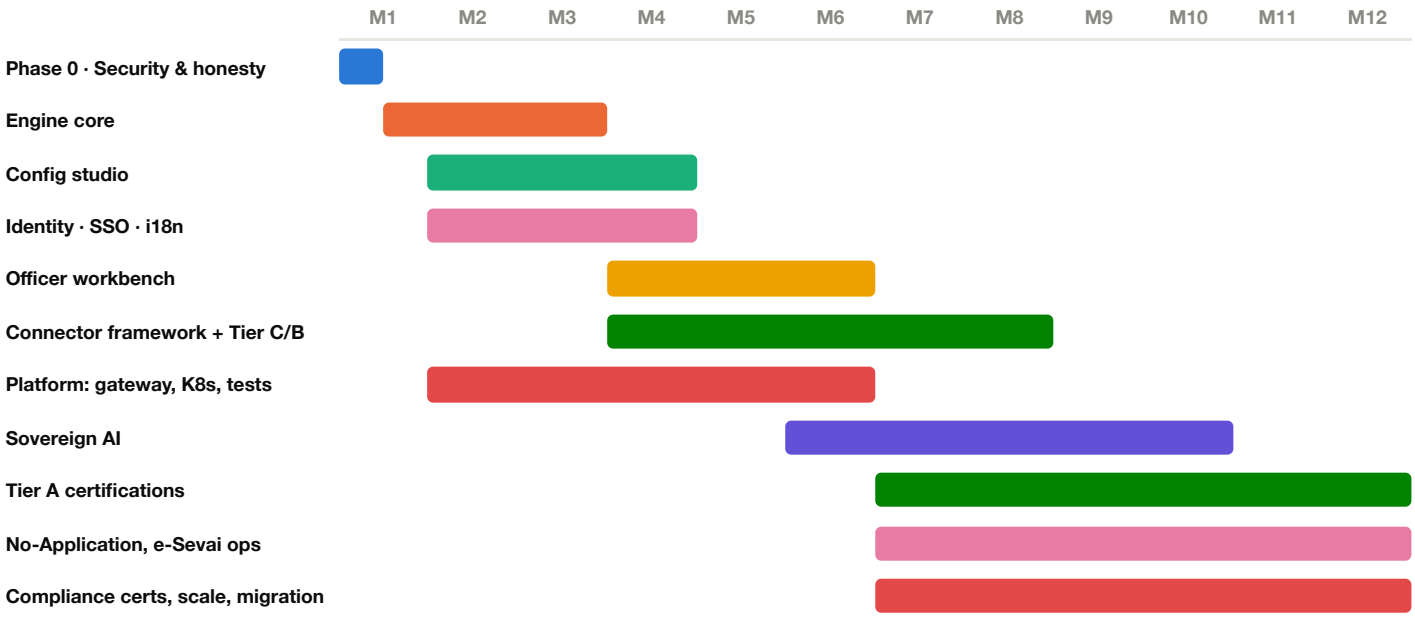



### Features by effort




XL items are mostly **external**: UIDAI, ESP, DigiLocker and PayGov onboarding, SFDB access, and the 110 TB migration. Their timelines are set by Government processes, not by code.

## Indicative roadmap (months from start)




Sequencing only. Durations depend on team size and on Government onboarding timelines; this is not a commitment.

# Feature backlog (1/3)

## Security & trust · 10 features

| ID | Feature | What it involves | Pri. | Effort | EOI ref |
|---|---|---|---|---|---|
| S1 | **Real authentication** | Mandatory SMS OTP (DLT), no client-chosen role, no credential-less biometric; mock flag OFF in production | P0 | S | F6-21, VAPT |
| S2 | **Identity binding** | Resolve user by identifier; server-assigned roles; fix refresh role drift | P0 | S | 5.2 h |
| S3 | **Kill self-approval** | Role-guard `/advance`; approve moves one level; maker-checker | P0 | S | F6-2 |
| S4 | **Owner & jurisdiction scoping** | Documents, notifications, officer queues | P0 | S | VAPT |
| S5 | **Aadhaar data vault** | Never store full Aadhaar; tokenise; purge OTP rows | P0 | M | Aadhaar Act |
| S6 | **Safe deploys** | `migrate deploy`; seed only by flag; backups | P0 | S | SZ-6 |
| S7 | **Secrets & containers** | No default secrets or published DB ports; non-root; Node LTS | P0 | S | VAPT |
| S8 | **Transport & storage security** | TLS, encryption at rest, CSP, private Swagger, hashed refresh tokens | P0 | M | GP-ix |
| S9 | **Complete audit trail** | Real actor, failed/denied requests, 180-day India retention | P0 | M | CERT-In |
| S10 | **Honest UI & docs** | Remove fabricated figures, "Govt of TN" branding, overclaiming copy | P0 | S | Cl. 9.5 |

## BPM engine core · 9 features

| ID | Feature | What it involves | Pri. | Effort | EOI ref |
|---|---|---|---|---|---|
| E1 | **Adopt a BPMN 2.0/DMN engine** | Operaton as a service; NestJS adapter; external-task workers on BullMQ/Valkey | P1 | L | F6-1, 5.2 c |
| E2 | **Model today's flow in BPMN** | Move application state onto process instances | P1 | M | F6-1 |
| E3 | **Approval chains 1–10 levels** | Sequential, parallel (multi-instance), return to any level | P1 | M | F6-2 |
| E4 | **Post & jurisdiction routing** | Posts, LGD-coded hierarchy, queues per post | P1 | L | F6-3 |
| E5 | **SLA timers & escalation** | Per-level SLA, reminders, auto-escalation, holiday calendar | P1 | M | F6-4 |
| E6 | **Process versioning** | Version pinning + in-flight instance migration | P1 | M | F6-5 |
| E7 | **DMN decision tables** | Eligibility, fees, document checklists (FEEL) | P1 | M | F6-6 |
| E8 | **Effective-dated rules** | Applied by application date | P1 | M | F6-8 |
| E9 | **BPMN/DMN XML import/export** | Portability to any compliant engine | P1 | S | F6-15, Q4 |

## No-code configuration studio · 8 features

| ID | Feature | What it involves | Pri. | Effort | EOI ref |
|---|---|---|---|---|---|
| C1 | **BPMN modeller** | bpmn-js; publish/deploy with maker-checker | P1 | M | F6-1 |
| C2 | **Rule builder** | dmn-js + plain-language Tamil/English builder, simulate | P1 | L | F6-7 |
| C3 | **Form builder** | Drag-and-drop JSON Schema forms, bilingual, server-side validation | P1 | L | F6-9 |
| C4 | **Single service registry** | Replace forms.ts/meta.ts + seed; onboarding wizard; bulk import | P1 | L | T1-4 |
| C5 | **Fee configuration** | Fee schedules linked to payments | P1 | M | 5.2 f |
| C6 | **Notification templates** | SMS/WhatsApp/e-mail/push, Tamil + English, DLT IDs | P1 | M | 5.2 f |
| C7 | **Certificate templates** | PDF + QR + e-Sign + DigiLocker push | P1 | L | 5.2 f |
| C8 | **User, role & tenant admin** | Department-scoped multi-tenancy | P1 | M | F6-21, 5.2 h |

# Feature backlog (2/3)

## Officer workbench · 6 features

| ID | Feature | What it involves | Pri. | Effort | EOI ref |
|---|---|---|---|---|---|
| O1 | **Scoped worklist** | By post, jurisdiction and department | P1 | M | F6-10 |
| O2 | **Full action set** | Return, forward, seek report with sub-tasks | P1 | M | F6-10 |
| O3 | **e-Sign / DSC + bulk signing** | ESP, DSC token/HSM | P1 | L | F6-11 |
| O4 | **Delegation, leave, FAC** | Charge handover with audit | P1 | M | F6-12 |
| O5 | **Department-user login** | Provision 50k–1 L users; optional HRMS sync | P1 | L | SZ-4 |
| O6 | **Decision-support workbench** | AI summaries, document checks | P2 | L | T1-3 |

## Citizen services & channels · 10 features

| ID | Feature | What it involves | Pri. | Effort | EOI ref |
|---|---|---|---|---|---|
| X1 | **CAN identity** | Issuance, de-dup engine, Aadhaar/ration linkage | P2 | L | T1-2 |
| X2 | **SSO** | Keycloak OIDC/SAML; Meri Pehchaan / TN SSO | P1 | L | 5.2 h, T2-5 |
| X3 | **"No Application" delivery** | SFDB-driven eligibility, proactive offers, consent pre-fill | P2 | XL | T1-7 |
| X4 | **Beneficiary management** | Scheme admin, eligible lists, disbursement | P2 | L | T1-8 |
| X5 | **Grievance redressal** | Workflow + IIPGCMS + AI dedup | P2 | L | T1-10 |
| X6 | **Channel APIs** | Versioned, partner auth; UMANG, WhatsApp, IVRS, call centre | P2 | L | T1-12 |
| X7 | **Native mobile support** | SDK, push, PWA/offline | P2 | M | F6-17 |
| X8 | **Complete Tamil/English** | All UI, forms, notifications, AI; lang tags | P1 | M | GP-vii |
| X9 | **e-Sevai centre operations** | Centre registry, operator console, assisted filing, commission | P2 | L | T1-9 |
| X10 | **Payments** | PayGov/UPI/AEPS, refunds, split settlement, reconciliation | P2 | L | T2-4 |

## DPI & department integrations · 5 features

| ID | Feature | What it involves | Pri. | Effort | EOI ref |
|---|---|---|---|---|---|
| I1 | **Connector framework** | REST/SOAP, retry, circuit breaker, DLQ, admin config | P1 | M | F6-13 |
| I2 | **Tier C connectors** | LGD, TNGIS, OGD, e-Taal | P2 | M | T2-15..18 |
| I3 | **Tier B connectors** | API Setu, Nambikkai, IIPGCMS, e-Courts, CCTNS, UMANG, comms, CSC | P2 | XL | T2-7..14 |
| I4 | **Tier A connectors** | Aadhaar, e-Sign, DigiLocker, PayGov, SSO, SFDB (certification-gated) | P2 | XL | T2-1..6 |
| I5 | **~15 departmental portals** | Municipal, rural dev, revenue, police, courts, schemes … | P2 | XL | T1-5 |

# Feature backlog (3/3)

## Sovereign AI · 6 features

| ID | Feature | What it involves | Pri. | Effort | EOI ref |
|---|---|---|---|---|---|
| A1 | **On-prem model serving** | vLLM + GPU sizing; remove browser speech APIs | P2 | L | HOST-b |
| A2 | **Conversational discovery** | Indic LLM + RAG over the service catalogue | P2 | L | T1-3 |
| A3 | **Tamil voice** | IndicConformer ASR + IndicF5 TTS | P2 | M | T1-3 |
| A4 | **Document intelligence** | Tamil OCR, extraction, verification | P2 | L | T1-3 |
| A5 | **Grievance AI** | Classification, routing, duplicate detection | P2 | M | T1-3 |
| A6 | **AI governance** | Evaluation, PII guardrails, egress control | P2 | M | 5.2 g |

## Platform, data & compliance · 16 features

| ID | Feature | What it involves | Pri. | Effort | EOI ref |
|---|---|---|---|---|---|
| P1 | **API gateway** | APISIX: routing, keys, quotas, metrics | P1 | M | F6-20 |
| P2 | **K8s, IaC, CI/CD** | Frontend image, Helm, pipelines | P1 | M | 5.2 d |
| P3 | **Automated tests** | Unit, integration, e2e, a11y, security | P1 | L | STQC |
| P4 | **Version currency + SBOM** | Nest 12, Prisma 7, PG 18, Valkey; licence register | P1 | M | 5.2 a-b |
| P5 | **Object storage** | SeaweedFS for documents; retention | P1 | M | GP-iv |
| P6 | **DPDPA consent manager** | Notices, purpose binding, rights, breach process | P1 | L | DPDPA |
| P7 | **VAPT readiness** | CERT-In findings closed; 2022 Directions | P1 | M | VAPT |
| P8 | **IPR & licence pack** | LICENSE, NOTICE, asset provenance, self-hosted fonts | P0 | S | 5.2 e |
| P9 | **HA & DR** | Replication, PITR, real health checks | P2 | L | SZ-6 |
| P10 | **Observability** | Prometheus, OTel, Jaeger, Grafana, alerts | P2 | M | F6-20 |
| P11 | **Performance at scale** | Pagination, caching, compression, load tests @50k | P2 | L | SZ-2,3,7 |
| P12 | **Real analytics + reports** | Data mart, no-code report builder, exports | P2 | L | F6-18,19 |
| P13 | **WCAG 2.1 AA + UX4G** | Audit, remediation, design system | P2 | L | Compliance |
| P14 | **GIGW 3.0 + DiTN** | Policy pages, sitemap, alignment matrix | P2 | M | Compliance |
| P15 | **STQC evidence** | SRS, test plans, traceability | P2 | L | STQC |
| P16 | **Legacy migration tooling** | ~110 TB ETL, reconciliation, documents | P2 | XL | T1-13 |

Effort: S < 1 week · M 1–4 weeks · L 1–3 months · XL > 3 months or external certification. Estimates are rough, for one developer per item.